Nhill — Référence de l'API v1

English: ../en/api-reference.md

Document **généré** depuis le code du serveur par `scripts/docs/gen_api_reference.py` (ne pas modifier à la main : modifier le code ou `scripts/docs/api_descriptions.py`, puis relancer le script ; l'intégration continue vérifie que ce fichier est à jour). Version 3.0.0 : 198 points d'accès en fonctionnement normal et 5 en mode installation.

Conventions

- Base : `https://<adresse du serveur>/api/v1` ; l'adresse est saisie dans les applications, aucune adresse n'y est compilée. JSON UTF-8. Langue des messages et des PDF : en-tête `Accept-Language` (`en…` → anglais, sinon français).
- Authentification : `Authorization: Bearer <jeton d'accès>` (15 minutes par défaut, `NH_ACCESS_TOKEN_MINUTES`), renouvelé par `POST /api/v1/auth/refresh`. La console utilise un jeton d'administration distinct, non interchangeable.
- Montants : chaînes décimales (`"1234.50"`) ; quantités : chaînes (`"2.5"`) ; taux : points de base entiers (`1600` = 16 %). Dates `AAAA-MM-JJ`, horodatages ISO 8601 UTC.
- Colonne « Idem. » : l'en-tête `Idempotency-Key` (UUID) est obligatoire (`400 idempotency_key_required`) ; un rejeu renvoie la même réponse avec `Idempotent-Replayed: true`.
- Pagination : `limit` (1 à 200), `offset`. Rapports : `from`, `to`, `format=json|csv|pdf`.
- Erreurs : `{"error": {"code", "message", "details", "request_id"}}`.

Contrôles d'accès

- **Public** : sans jeton. **Utilisateur** : membre d'un établissement. **Console** : administrateur de la plateforme (colonne « Rôles console » ; `superadmin` a tous les droits). **Webhook** : signature du prestataire. **Installation** : serveur sans base, jeton d'installation affiché dans son journal.
- « Permission » : droit du rôle exigé (tableau ci-dessous) ; sinon `403 permission_denied`.
- « Formule » : fonction que la formule de l'établissement doit comprendre (`a|b` : l'une ou l'autre) ; sinon `403 feature_not_included`. Une permission `pos.*`, `purchases.*` ou `expenses.*` exige aussi la fonction correspondante. Certaines routes vérifient en plus une fonction selon le contenu : type de document (devis et commandes → `sales.quotes`, factures et avoirs → `sales.invoices`), devise autre que la devise principale (`multi_currency`), dépôt autre que le dépôt principal (`stock.multi_warehouse`). Les listes ne renvoient que les données des fonctions comprises.
- « Écrit. » : écriture permise seulement avec un accès complet ; abonnement en lecture seule → `402 subscription_suspended` ; établissement suspendu par la plateforme → `403 establishment_suspended`. Établissement fermé ou sans accès → `403 establishment_closed` sur toutes les routes utilisateur.
- Limites de la formule (utilisateurs, caisses, dépôts, produits, documents par mois, stockage) : dépassement → `409 plan_limit_reached` (`user_limit_reached` pour les utilisateurs, `plan_register_limit` pour les caisses), avec `limit_key`, `limit` et `used` dans `details`.

Permissions par rôle

Rôle	Permissions
Propriétaire (`owner`)	`settings.manage`, `users.manage`, `code.view`, `code.rotate`, `subscription.manage`, `catalog.write`, `parties.write`, `sales.write`, `sales.issue`, `purchases.write`, `stock.adjust`, `expenses.write`, `payments.write`, `reports.read`, `audit.read`, `pos.sell`, `pos.refund`, `pos.void`, `pos.cash`, `pos.supervise`, `pos.manage`, `pos.report`
Administrateur (`admin`)	`settings.manage`, `users.manage`, `code.view`, `code.rotate`, `subscription.manage`, `catalog.write`, `parties.write`, `sales.write`, `sales.issue`, `purchases.write`, `stock.adjust`, `expenses.write`, `payments.write`, `reports.read`, `audit.read`, `pos.sell`, `pos.refund`, `pos.void`, `pos.cash`, `pos.supervise`, `pos.manage`, `pos.report`
Gérant (`manager`)	`code.view`, `catalog.write`, `parties.write`, `sales.write`, `sales.issue`, `purchases.write`, `stock.adjust`, `expenses.write`, `payments.write`, `reports.read`, `pos.sell`, `pos.refund`, `pos.supervise`, `pos.report`
Vendeur (`sales`)	`parties.write`, `sales.write`, `sales.issue`, `payments.write`, `pos.sell`
Comptable (`accountant`)	`expenses.write`, `payments.write`, `reports.read`, `audit.read`, `pos.report`
Lecture seule (`viewer`)	aucune écriture
Responsable de caisse (`cash_manager`)	`pos.sell`, `pos.refund`, `pos.void`, `pos.cash`, `pos.supervise`, `pos.report`
Caissier (`cashier`)	`pos.sell`

Mode installation (serveur sans base)

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/health`	Installation	—	—	—	—	—	Serveur en attente d'installation : `{"status":"setup","database":false}`
GET	`/api/v1/meta`	Installation	—	—	—	—	—	Identité du serveur (produit, version, API, version minimale du client) avec `mode: setup` ; les applications l'utilisent pour vérifier une adresse avant de l'enregistrer
GET	`/api/v1/setup/status`	Installation	—	—	—	—	—	`setup` ou `restarting` (installation terminée, redémarrage en cours) et version
POST	`/api/v1/setup/check`	Installation	—	—	—	—	—	Teste la connexion à la base `{setup_token, database:{…}}` sans rien écrire ; jeton affiché dans le journal du serveur, valable 60 min, 20 essais par 15 min et par adresse IP

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
POST	`/api/v1/setup/apply`	Installation	—	—	—	—	—	Installe : enregistre la configuration, applique les migrations, crée éventuellement le premier administrateur `{first_admin:{email, full_name}}` (jeton de premier accès renvoyé une fois), puis le serveur redémarre en mode normal ; `409 already_installed` ensuite

Service et référentiels

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/health`	Public	—	—	—	—	—	État du service et de la base (200 `ok`, 503 dégradé)
GET	`/api/v1/meta`	Public	—	—	—	—	—	Version, version minimale du client, pays, devises (36), langues
GET	`/api/v1/countries/:cc/profile`	Public	—	—	—	—	—	Profil pays : identifiants légaux, taxes, mentions, numérotation

Inscription et rattachement

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
POST	`/api/v1/establishments`	Public	—	—	—	—	—	Création d'un établissement : établissement, propriétaire, formule attribuée (essai ou règle d'attribution) et code ; refuse un doublon d'identifiant légal (`establishment_exists`)
POST	`/api/v1/establishments/attachment-requests`	Public	—	—	—	—	—	Demande de rattachement à une entreprise existante (réponse identique que l'entreprise existe ou non)
POST	`/api/v1/join/check-code`	Public	—	—	—	—	—	Rejoindre, étape 1 : code d'établissement → ticket de 10 min (erreur générique, limité par adresse IP)
POST	`/api/v1/join/login`	Public	—	—	—	—	—	Rejoindre : ticket + e-mail + mot de passe d'un membre
POST	`/api/v1/join/activate`	Public	—	—	—	—	—	Rejoindre : ticket + e-mail + code d'invitation → création du compte et de la session

Authentification et compte

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
POST	`/api/v1/auth/login`	Public	—	—	—	—	—	Connexion (e-mail, mot de passe, établissement si plusieurs). Av passe temporaire : `{"password_change_required":true,"change_token","` au lieu d'une session ; temporaire expiré → `401 temporary_password_expired`
POST	`/api/v1/auth/refresh`	Public	—	—	—	—	—	Rotation du jeton de rafraîchissement (réutilisation détectée → re session)
POST	`/api/v1/auth/logout`	Utilisateur	—	—	—	—	—	Fermeture de la session courante
GET	`/api/v1/me`	Utilisateur	—	—	—	—	—	Utilisateur, rôle, permissions, version des droits, établissement, a (détail pour le propriétaire et les administrateurs, état d'accès po droits de la formule et usage, autres établissements
PATCH	`/api/v1/me`	Utilisateur	—	—	—	—	—	Nom, téléphone, langue
POST	`/api/v1/me/password`	Utilisateur	—	—	—	—	—	Changement de mot de passe (ferme les autres sessions)
POST	`/api/v1/auth/password/forgot`	Public	—	—	—	—	—	Mot de passe oublié `{email}` → **toujours** `202`. Code à 8 chiffre pour un propriétaire, un administrateur ou un compte de plusieu établissements ; consigne « contactez votre administrateur » pou d'un seul établissement ; rien pour une adresse inconnue. 3 dem et par adresse, 10 par heure et par IP
POST	`/api/v1/auth/password/reset`	Public	—	—	—	—	—	`{email, code, new_password}` → 204 ; code faux, expiré ou `invalid_reset_code` (même erreur dans tous les cas) ; toutes sont fermées
POST	`/api/v1/auth/password/change-required`	Public	—	—	—	—	—	`{change_token, new_password}` après une connexion avec temporaire ; ticket de 15 min à usage unique (`400 invalid_ch` `422 password_reused` si identique au temporaire ; même rép connexion
POST	`/api/v1/me/switch`	Utilisateur	—	—	—	—	—	Changer d'établissement sans ressaisir le mot de passe
GET	`/api/v1/notifications`	Utilisateur	—	—	—	—	—	Notifications de l'utilisateur
POST	`/api/v1/notifications/:id/read`	Utilisateur	—	—	—	—	—	Marquer une notification comme lue
POST	`/api/v1/members/:id/password-reset`	Utilisateur	`users.manage`	—	—	—	—	Mot de passe temporaire pour un membre de **cet** établissement, seule fois ; refusé pour soi-même, le propriétaire, un administrat n'est pas propriétaire, un membre désactivé (`409 member_dis` compte actif dans un autre établissement (`409 account_shar` min et par auteur
GET	`/api/v1/members`	Utilisateur	`users.manage`	—	—	—	—	Membres, invitations en attente, limite d'utilisateurs de la formul

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
PATCH	`/api/v1/members/:id`	Utilisateur	`users.manage`	—	—	—	—	Changer le rôle ou désactiver un membre (sessions révoquées)

Établissement, équipe et droits

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/entitlements`	Utilisateur	—	—	—	—	—	Droits de l'établissement : fonctions comprises dans la formule (jamais celles qui n'y sont pas), limites et usage, libellés FR/EN, version des droits
GET	`/api/v1/establishment`	Utilisateur	—	—	—	—	—	Fiche de l'établissement, paramètres, mention de conformité
PATCH	`/api/v1/establishment`	Utilisateur	`settings.manage`	—	oui	—	—	Modifier la fiche
PUT	`/api/v1/establishment/legal-ids`	Utilisateur	`settings.manage`	—	oui	—	—	Remplacer les identifiants légaux (validés selon le profil pays)
PATCH	`/api/v1/establishment/settings`	Utilisateur	`settings.manage`	—	oui	—	—	Paramètres des documents : langue, délai de paiement, arrondi des taxes, pied de page, instructions de paiement, mentions (FR/EN), stock négatif
PUT	`/api/v1/establishment/logo`	Utilisateur	`settings.manage`	—	oui	—	—	Téléverser le logo (PNG ou JPEG, corps brut, contenu réel vérifié)
GET	`/api/v1/establishment/logo`	Utilisateur	—	—	—	—	—	Lire le logo
DELETE	`/api/v1/establishment/logo`	Utilisateur	`settings.manage`	—	oui	—	—	Supprimer le logo
GET	`/api/v1/establishment/code`	Utilisateur	`code.view`	—	—	—	—	Code d'établissement en cours et date de renouvellement
POST	`/api/v1/establishment/code/rotate`	Utilisateur	`code.rotate`	—	—	—	—	Renouveler le code immédiatement
GET	`/api/v1/establishment/audit`	Utilisateur	`audit.read`	—	—	—	—	Journal brut (point d'accès conservé ; préférer `/api/v1/activity`)
GET	`/api/v1/establishment/export`	Utilisateur	—	—	—	—	—	Archive ZIP complète des données de l'établissement (JSON, CSV, pièces jointes, manifeste avec empreintes SHA-256) ; propriétaire seulement, même abonnement suspendu ou expiré ; 3 par 15 min
POST	`/api/v1/invitations`	Utilisateur	`users.manage`	—	oui	—	—	Inviter (e-mail, rôle) dans la limite d'utilisateurs ; code d'activation renvoyé une seule fois
DELETE	`/api/v1/invitations/:id`	Utilisateur	`users.manage`	—	—	—	—	Révoquer une invitation

Abonnement et paiement

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/plans`	Public	—	—	—	—	—	Formules publiées avec leurs prix par durée et devise, limites et fonctions
GET	`/api/v1/subscription`	Utilisateur	`subscription.manage`	—	—	—	—	Abonnement (formule, prix, échéance, changement prévu, échecs), commandes, historique
POST	`/api/v1/subscription/quote`	Utilisateur	`subscription.manage`	—	—	—	—	Devis calculé par le serveur `{price_id, promo_code}` → type (nouveau, renouvellement, montée, descente), prix, remise, crédit au prorata, total
POST	`/api/v1/subscription/orders`	Utilisateur	`subscription.manage`	—	—	—	—	Créer la commande (`price_id`, `promo_code`, `provider`) ; total nul → appliquée immédiatement
POST	`/api/v1/subscription/orders/:id/checkout`	Utilisateur	`subscription.manage`	—	—	—	—	Créer la session de paiement chez le prestataire → `checkout_url`
POST	`/api/v1/subscription/orders/:id/cancel`	Utilisateur	`subscription.manage`	—	—	—	—	Annuler une commande non payée (code promotionnel libéré)
POST	`/api/v1/subscription/auto-renew`	Utilisateur	`subscription.manage`	—	—	—	—	Donner ou retirer l'accord exprès au renouvellement automatique
GET	`/payment/return`	Public	—	—	—	—	—	Page HTML de retour après paiement (n'active rien)
POST	`/api/v1/webhooks/payments/:provider`	Webhook	—	—	—	—	—	Notification du prestataire de paiement : signature vérifiée, dédoublonnage, relecture chez le prestataire

Assistance

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/support/tickets`	Utilisateur	—	—	—	—	—	Demandes d'assistance : les siennes ; toutes celles de l'établissement avec `users.manage`
POST	`/api/v1/support/tickets`	Utilisateur	—	—	—	—	—	Nouvelle demande `{category: bug|question|billing|feature, subject, body}` (20 par jour)
GET	`/api/v1/support/tickets/:id`	Utilisateur	—	—	—	—	—	Demande et messages (notes internes de l'équipe exclues)
POST	`/api/v1/support/tickets/:id/messages`	Utilisateur	—	—	—	—	—	Répondre
POST	`/api/v1/support/tickets/:id/close`	Utilisateur	—	—	—	—	—	Fermer la demande
POST	`/api/v1/client-errors`	Utilisateur	—	—	—	—	—	Rapport d'erreur technique d'une application (données personnelles masquées)

Catalogue

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/tax-rates`	Utilisateur	—	—	—	—	—	Taux de taxe
POST	`/api/v1/tax-rates`	Utilisateur	`settings.manage`	—	oui	—	—	Créer un taux
PATCH	`/api/v1/tax-rates/:id`	Utilisateur	`settings.manage`	—	oui	—	—	Libellé, actif, défaut (le taux lui-même ne change pas)
GET	`/api/v1/product-categories`	Utilisateur	—	—	—	—	—	Catégories de produits
POST	`/api/v1/product-categories`	Utilisateur	`catalog.write`	—	oui	—	—	Créer une catégorie
DELETE	`/api/v1/product-categories/:id`	Utilisateur	`catalog.write`	—	oui	—	—	Supprimer une catégorie vide
GET	`/api/v1/products`	Utilisateur	—	—	—	—	—	Produits et services (recherche, catégorie, stock bas, pagination)
GET	`/api/v1/products/export.csv`	Utilisateur	—	—	—	—	—	Export CSV du catalogue
GET	`/api/v1/products/:id`	Utilisateur	—	—	—	—	—	Produit
POST	`/api/v1/products`	Utilisateur	`catalog.write`	—	oui	—	—	Créer un produit ou un service (dans la limite de produits de la formule)
PATCH	`/api/v1/products/:id`	Utilisateur	`catalog.write`	—	oui	—	—	Modifier un produit
POST	`/api/v1/products/import`	Utilisateur	`catalog.write`	`catalog.import`	oui	—	—	Import CSV tout ou rien (erreurs par ligne)

Clients et fournisseurs

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/customers`	Utilisateur	—	—	—	—	—	Clients (recherche, soldes)
GET	`/api/v1/suppliers`	Utilisateur	—	`purchases|expenses`	—	—	—	Fournisseurs
GET	`/api/v1/parties/:id`	Utilisateur	—	—	—	—	—	Tiers, soldes, documents
POST	`/api/v1/parties`	Utilisateur	`parties.write`	—	oui	—	—	Créer un client et/ou un fournisseur
PATCH	`/api/v1/parties/:id`	Utilisateur	`parties.write`	—	oui	—	—	Modifier un tiers

Documents de vente

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/sales-documents`	Utilisateur	—	—	—	—	—	Documents (type, statut, tiers, période, recherche, retard) ; seulement les types compris dans la formule
GET	`/api/v1/sales-documents/:id`	Utilisateur	—	—	—	—	—	Document complet, paiements, historique
GET	`/api/v1/sales-documents/:id/pdf`	Utilisateur	—	—	—	—	—	PDF du document : `format=a4|ticket`, `width=58|80` (même document dans les deux mises en page ; `inline` pour l'affichage)
POST	`/api/v1/sales-documents`	Utilisateur	`sales.write`	—	oui	oui	—	Créer un brouillon (idempotent)
PUT	`/api/v1/sales-documents/:id`	Utilisateur	`sales.write`	—	oui	—	—	Modifier un brouillon
DELETE	`/api/v1/sales-documents/:id`	Utilisateur	`sales.write`	—	oui	—	—	Supprimer un brouillon (jamais un document émis)
POST	`/api/v1/sales-documents/:id/issue`	Utilisateur	`sales.issue`	—	oui	oui	—	Émettre : numéro définitif, stock, taux de change figé, empreinte du PDF (idempotent ; limite de documents par mois, jamais pour un avoir)

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
POST	`/api/v1/sales-documents/:id/status`	Utilisateur	`sales.write`	—	oui	—	—	Transition contrôlée (devis accepté ou refusé, commande annulée)
POST	`/api/v1/sales-documents/:id/convert`	Utilisateur	`sales.write`	—	oui	oui	—	Devis ou commande → commande ou facture (brouillon)
POST	`/api/v1/sales-documents/:id/credit-note`	Utilisateur	`sales.issue`	—	oui	oui	—	Brouillon d'avoir sur une facture émise (option de remise en stock)
PUT	`/api/v1/sales-documents/:id/fiscal-reference`	Utilisateur	`sales.issue`	—	oui	—	—	Enregistrer la référence de la facture normalisée émise par le dispositif agréé (rapprochement, aucune certification)

Achats

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/purchases`	Utilisateur	—	`purchases`	—	—	—	Achats
GET	`/api/v1/purchases/:id`	Utilisateur	—	`purchases`	—	—	—	Achat
POST	`/api/v1/purchases`	Utilisateur	`purchases.write`	`purchases`	oui	oui	—	Créer un achat brouillon (idempotent)
PUT	`/api/v1/purchases/:id`	Utilisateur	`purchases.write`	`purchases`	oui	—	—	Modifier un brouillon
POST	`/api/v1/purchases/:id/receive`	Utilisateur	`purchases.write`	`purchases`	oui	oui	—	Réceptionner : entrées de stock, prix d'achat mis à jour (idempotent)
POST	`/api/v1/purchases/:id/cancel`	Utilisateur	`purchases.write`	`purchases`	oui	—	—	Annuler un brouillon

Stock

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/warehouses`	Utilisateur	—	—	—	—	—	Dépôts (et indication du droit à plusieurs dépôts)
POST	`/api/v1/warehouses`	Utilisateur	`stock.adjust`	`stock.multi_warehouse`	oui	—	—	Créer un dépôt (dans la limite de dépôts de la formule)
GET	`/api/v1/stock`	Utilisateur	—	—	—	—	—	Niveaux de stock et valeur estimée
GET	`/api/v1/stock/movements`	Utilisateur	—	—	—	—	—	Mouvements de stock
POST	`/api/v1/stock/adjustments`	Utilisateur	`stock.adjust`	—	oui	oui	—	Ajustement ou stock d'ouverture, motif obligatoire (idempotent)
POST	`/api/v1/stock/transfers`	Utilisateur	`stock.adjust`	`stock.multi_warehouse`	oui	oui	—	Transfert entre dépôts (idempotent)

Dépenses

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/expense-categories`	Utilisateur	—	`expenses`	—	—	—	Catégories de dépenses
POST	`/api/v1/expense-categories`	Utilisateur	`expenses.write`	`expenses`	oui	—	—	Créer une catégorie
GET	`/api/v1/expenses`	Utilisateur	—	`expenses`	—	—	—	Dépenses (période, catégorie, impayées)
POST	`/api/v1/expenses`	Utilisateur	`expenses.write`	`expenses`	oui	oui	—	Créer une dépense, éventuellement payée (idempotent)
PUT	`/api/v1/expenses/:id/receipt`	Utilisateur	`expenses.write`	`expenses`	oui	—	—	Joindre un justificatif (PDF, PNG ou JPEG, 5 Mo ; limite de stockage de la formule)
GET	`/api/v1/expenses/:id/receipt`	Utilisateur	—	`expenses`	—	—	—	Lire le justificatif

Paiements, caisses et taux de change

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/payments`	Utilisateur	—	—	—	—	—	Paiements (sens, période)
POST	`/api/v1/payments`	Utilisateur	`payments.write`	—	oui	oui	—	Paiement d'une facture, d'un avoir (remboursement), d'un achat ou d'une dépense — jamais au-delà du reste dû (idempotent)
GET	`/api/v1/cash-accounts`	Utilisateur	—	—	—	—	—	Caisses et comptes, solde enregistré
POST	`/api/v1/cash-accounts`	Utilisateur	`settings.manage`	—	oui	—	—	Créer une caisse ou un compte
GET	`/api/v1/exchange-rates`	Utilisateur	—	`multi_currency`	—	—	—	Taux de change enregistrés

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
POST	`/api/v1/exchange-rates`	Utilisateur	`settings.manage`	`multi_currency`	oui	—	—	Enregistrer un taux (date et source)

Caisse (Nhill POS)

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/pos/config`	Utilisateur	`pos.sell`	`pos`	—	—	—	Caisses accessibles, moyens de paiement, règles, permissions, session ouverte de l'utilisateur
GET	`/api/v1/pos/catalog`	Utilisateur	`pos.sell`	`pos`	—	—	—	`?register_id=` : produits actifs avec prix, taxe et stock du dépôt de la caisse
GET	`/api/v1/pos/registers`	Utilisateur	`pos.report`	`pos`	—	—	—	Caisses, moyens de paiement, règles ; limite de caisses de la formule
POST	`/api/v1/pos/registers`	Utilisateur	`pos.manage`	`pos`	oui	—	—	Créer une caisse (code, nom, emplacement, dépôt) dans la limite de caisses de la formule
PATCH	`/api/v1/pos/registers/:id`	Utilisateur	`pos.manage`	`pos`	oui	—	—	Modifier, activer ou désactiver une caisse
PUT	`/api/v1/pos/registers/:id/users`	Utilisateur	`pos.manage`	`pos`	oui	—	—	Caissiers autorisés `{user_ids}` (membres actifs seulement)
POST	`/api/v1/pos/payment-methods`	Utilisateur	`pos.manage`	`pos`	oui	—	—	Ajouter un moyen de paiement
PATCH	`/api/v1/pos/payment-methods/:id`	Utilisateur	`pos.manage`	`pos`	oui	—	—	Modifier, activer ou désactiver un moyen de paiement
PATCH	`/api/v1/pos/settings`	Utilisateur	`pos.manage`	`pos`	oui	—	—	`max_discount_bp`, `allow_price_override`, `receipt_footer`, `receipt_width_mm` (58 ou 80)
GET	`/api/v1/pos/promo-codes`	Utilisateur	`pos.manage`	`pos`	—	—	—	Codes promotionnels de vente de l'établissement et nombre d'utilisations
POST	`/api/v1/pos/promo-codes`	Utilisateur	`pos.manage`	`pos`	oui	—	—	Créer un code promotionnel de vente (pourcentage, montant minimal, validité, nombre maximal)
PATCH	`/api/v1/pos/promo-codes/:id`	Utilisateur	`pos.manage`	`pos`	oui	—	—	Modifier la validité ou activer / désactiver un code
POST	`/api/v1/pos/approvals`	Utilisateur	`pos.sell`	`pos`	—	—	—	Autorisation d'un responsable `{email, password, action, session_id}` → jeton à usage unique (3 min)
POST	`/api/v1/pos/sessions`	Utilisateur	`pos.sell`	`pos`	oui	—	—	Ouvrir une session `{register_id, opening_float}`
GET	`/api/v1/pos/sessions`	Utilisateur	—	`pos`	—	—	—	Sessions de caisse : les siennes, toutes avec `pos.report` (filtre `register_id`, pagination)
GET	`/api/v1/pos/sessions/:id`	Utilisateur	—	`pos`	—	—	—	Détail d'une session : ventes et retours, encaissements par moyen, taxes, mouvements d'espèces, espèces attendues et écart, documents émis
POST	`/api/v1/pos/sessions/:id/cash-movements`	Utilisateur	`pos.sell`	`pos`	oui	oui	—	Entrée ou sortie d'espèces (sortie : `pos.cash` ou autorisation)
POST	`/api/v1/pos/sessions/:id/close`	Utilisateur	`pos.sell`	`pos`	oui	oui	—	Clôture `{counted: {moyen: montant}, note}` (espèces obligatoires)
GET	`/api/v1/pos/sessions/:id/report.pdf`	Utilisateur	—	`pos`	—	—	—	Lecture X (session ouverte) ou rapport Z (session clôturée)
POST	`/api/v1/pos/sales`	Utilisateur	`pos.sell`	`pos`	oui	oui	—	Vente `{session_id, lines, document: receipt|invoice, customer_id?, promo_code?, payments, approval_token?}` → `{receipt, change}` ; une facture exige un client identifié
GET	`/api/v1/pos/sales/:id/receipt.pdf`	Utilisateur	`pos.sell`	`pos`	—	oui	—	PDF de la vente : ticket 58/80 mm ou facture A4, même modèle que Nhill Business
POST	`/api/v1/pos/sales/:id/return`	Utilisateur	`pos.sell`	`pos`	oui	—	—	Retour `{session_id, reason, lines[{line_no, quantity}], refunds?, restock}` (`pos.refund` ou autorisation)
POST	`/api/v1/pos/sales/:id/void`	Utilisateur	`pos.sell`	`pos`	oui	—	—	Annulation du ticket dans sa session (`pos.void` ou autorisation)
GET	`/api/v1/pos/receipts`	Utilisateur	`pos.sell`	`pos`	—	—	—	`?number=` : retrouver un ticket ou une facture de caisse par son numéro

Rapports et journal d'activité

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/activity`	Utilisateur	—	—	—	—	—	Journal d'activité : filtres `user_id`, `action` (préfixe), `from`, `to`, pagination, `format=csv|pdf` ; sans `audit.read`, ses propres actions seulement

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/reports/staff`	Utilisateur	`audit.read`	`reports.advanced`	—	—	—	Activité par employé et par devise (`from`, `to`, `format`)
GET	`/api/v1/reports/dashboard`	Utilisateur	—	—	—	—	—	Tableau de bord (`from`, `to`) ; périmètre personnel sans `reports.read` ; indicateurs limités aux fonctions de la formule
GET	`/api/v1/reports/sales`	Utilisateur	`reports.read`	`sales.invoices|pos`	—	—	—	Journal des ventes (avec « Émis par »)
GET	`/api/v1/reports/expenses`	Utilisateur	`reports.read`	`expenses`	—	—	—	Dépenses
GET	`/api/v1/reports/stock-movements`	Utilisateur	`reports.read`	—	—	—	—	Mouvements de stock
GET	`/api/v1/reports/receivables`	Utilisateur	`reports.read`	`sales.invoices`	—	—	—	Créances clients à ce jour
GET	`/api/v1/reports/payables`	Utilisateur	`reports.read`	`purchases|expenses`	—	—	—	Dettes à ce jour
GET	`/api/v1/reports/payments`	Utilisateur	`reports.read`	—	—	—	—	Paiements (avec « Enregistré par »)
GET	`/api/v1/reports/products`	Utilisateur	`reports.read`	`reports.advanced`	—	—	—	Ventes par produit, marge estimée

Console — accès des administrateurs

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
POST	`/api/v1/admin/auth/setup`	Public	—	—	—	—	—	Premier accès : jeton d'initialisation + mot de passe (8 caractères au moins, pas un mot de passe trop courant) → secret TOTP
POST	`/api/v1/admin/auth/setup/confirm`	Public	—	—	—	—	—	Premier accès : code TOTP → compte actif
POST	`/api/v1/admin/auth/login`	Public	—	—	—	—	—	Connexion : e-mail + mot de passe + code TOTP (code non rejouable)
POST	`/api/v1/admin/auth/logout`	Console	—	—	—	—	—	Fermer la session d'administration
GET	`/api/v1/admin/me`	Console	—	—	—	—	—	Administrateur courant
POST	`/api/v1/admin/admins`	Console	—	—	—	—	`superadmin`	Inviter un administrateur ; jeton d'initialisation affiché une seule fois

Console — établissements

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/admin/establishments`	Console	—	—	—	—	—	Liste des établissements (recherche, état d'abonnement, `erasable=true` : établisse supprimer)
GET	`/api/v1/admin/establishments/:id`	Console	—	—	—	—	—	Fiche plateforme : abonnement, codes (sans valeur), usage sur 30 jours, état de suppressi
POST	`/api/v1/admin/establishments/:id/suspend`	Console	—	—	—	—	`support`	Suspendre avec motif ; sessions révoquées
POST	`/api/v1/admin/establishments/:id/reactivate`	Console	—	—	—	—	`support`	Réactiver avec motif
POST	`/api/v1/admin/establishments/:id/erase`	Console	—	—	—	—	`superadmin`	Suppression définitive `{reason, confirm_trade_name, customer_reque` possible 90 jours après la fin de l'accès, plus seulement à la demande du client et jamais p un accès complet (`409 not_erasable`) ; commandes payées archivées 10 ans ; inscri journal de la plateforme
POST	`/api/v1/admin/establishments/:id/codes/reissue`	Console	—	—	—	—	`support`	Réémettre le code avec motif ; le code n'est p montré à l'administrateur
GET	`/api/v1/admin/attachment-requests`	Console	—	—	—	—	`support`	Demandes de rattachement
POST	`/api/v1/admin/attachment-requests/:id/resolve`	Console	—	—	—	—	`support`	Accepter ou refuser avec une note
GET	`/api/v1/admin/establishments/:id/stats`	Console	—	—	—	—	`billing`, `auditor`	Statistiques **agrégées** sur une période ; cons inscrite au journal et visible par l'établisseme
POST	`/api/v1/admin/establishments/:id/subscription`	Console	—	—	—	—	`billing`	`{action: extend|suspend|reactivate|cancel|s reason}` — motif obligatoire, inscrit au journ établissement notifié
POST	`/api/v1/admin/establishments/:id/orders`	Console	—	—	—	—	`billing`	Créer une demande de paiement pour un établissement
GET	`/api/v1/admin/establishments/:id/entitlements`	Console	—	—	—	—	—	Droits effectifs de l'établissement (toutes les fonctions, activées ou non) et compteurs d'u jamais le contenu

Console — formules et droits

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/admin/plans`	Console	—	—	—	—	—	Formules
POST	`/api/v1/admin/plans`	Console	—	—	—	—	`billing`	Créer une formule (code, noms et descriptions FR/EN, public visé, niveau, limites, fonctions)
PATCH	`/api/v1/admin/plans/:id`	Console	—	—	—	—	`billing`	Modifier une formule et ses conditions (essai, période de grâce, rappels, souscription en libre-service, renouvellement automatique, formule de repli à l'échéance, archivage) ; s'applique aux futures demandes
POST	`/api/v1/admin/plans/:id/prices`	Console	—	—	—	—	`billing`	Ajouter ou remplacer un prix (durée de 1, 3, 6, 12, 24 ou 36 mois, devise)
PATCH	`/api/v1/admin/plan-prices/:id`	Console	—	—	—	—	`billing`	Modifier ou retirer un prix
GET	`/api/v1/admin/capabilities`	Console	—	—	—	—	—	Catalogue des fonctions et des limites (la liste suit le code du serveur)
PATCH	`/api/v1/admin/capabilities/:key`	Console	—	—	—	—	`superadmin`	Modifier les libellés et descriptions FR/EN d'une fonction ou d'une limite
GET	`/api/v1/admin/plans/:id/entitlements`	Console	—	—	—	—	—	Valeurs de la formule pour chaque fonction et limite, avec le catalogue
PUT	`/api/v1/admin/plans/:id/entitlements`	Console	—	—	—	—	`billing`	Remplacer toutes les valeurs de la formule (une entrée absente prend la valeur par défaut du catalogue) ; les établissements abonnés reçoivent leurs nouveaux droits à leur prochaine requête ; avant/après inscrits au journal
GET	`/api/v1/admin/plan-rules`	Console	—	—	—	—	—	Règles d'attribution de formule
POST	`/api/v1/admin/plan-rules`	Console	—	—	—	—	`billing`	Créer une règle `{plan_id, mode: trial|grant, audience, country_code, duration_days, priority}` ; une attribution sans durée est réservée aux formules gratuites ou sur mesure
PATCH	`/api/v1/admin/plan-rules/:id`	Console	—	—	—	—	`billing`	Modifier une règle
DELETE	`/api/v1/admin/plan-rules/:id`	Console	—	—	—	—	`billing`	Supprimer une règle

Console — facturation

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/admin/orders`	Console	—	—	—	—	—	Demandes de paiement d'abonnement
POST	`/api/v1/admin/orders/:id/confirm-manual`	Console	—	—	—	—	`billing`	Confirmation manuelle d'un virement : référence + motif, inscrite au journal
GET	`/api/v1/admin/webhook-events`	Console	—	—	—	—	`billing`, `auditor`	Événements reçus des prestataires
GET	`/api/v1/admin/transactions`	Console	—	—	—	—	`billing`, `auditor`	Transactions d'abonnement (statut, prestataire, établissement, période, pagination)
GET	`/api/v1/admin/transactions/:id`	Console	—	—	—	—	`billing`, `auditor`	Détail d'une transaction et références chez le prestataire
GET	`/api/v1/admin/payment-providers`	Console	—	—	—	—	`billing`	Prestataires de paiement configurés (secrets jamais renvoyés) et adresse publique de retour
POST	`/api/v1/admin/payment-providers`	Console	—	—	—	—	`superadmin`	Ajouter un prestataire (`stripe`, `paypal`, `payoneer` sans adaptateur, `generic_hmac`) ; secrets chiffrés
PATCH	`/api/v1/admin/payment-providers/:id`	Console	—	—	—	—	`superadmin`	Modifier un prestataire, ses secrets ou son activation
GET	`/api/v1/admin/promo-codes`	Console	—	—	—	—	`billing`	Codes promotionnels d'abonnement
POST	`/api/v1/admin/promo-codes`	Console	—	—	—	—	`billing`	Créer un code (pourcentage ou montant fixe dans une devise)
PATCH	`/api/v1/admin/promo-codes/:id`	Console	—	—	—	—	`billing`	Modifier la validité, les limites ou l'activation (code et remise non modifiables)
GET	`/api/v1/admin/promo-codes/:id/redemptions`	Console	—	—	—	—	`billing`, `auditor`	Utilisations d'un code

Console — assistance et exploitation

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
GET	`/api/v1/admin/audit`	Console	—	—	—	—	`auditor`, `support`	Journal de la plateforme ; détails des actions métier masqués
GET	`/api/v1/admin/stats`	Console	—	—	—	—	—	Chiffres globaux de la plateforme
GET	`/api/v1/admin/announcements`	Console	—	—	—	—	—	Annonces

Méthode	Chemin	Accès	Permission	Formule	Écrit.	Idem.	Rôles console	Description
POST	`/api/v1/admin/announcements`	Console	—	—	—	—	`support`	Publier une annonce
GET	`/api/v1/admin/settings`	Console	—	—	—	—	—	Paramètres de la plateforme
PUT	`/api/v1/admin/settings/:key`	Console	—	—	—	—	`superadmin`	Modifier un paramètre de la liste autorisée : `trial_days` 0–365, `grace_days` 0–60, `reminder_days_before` 1–60, `code_rotation_days` 1–365, `code_check_max_per_15min` et `login_max_per_15min` 3–100, `invitation_days` 1–60, `trial_max_users` 1–1000, `password_reset_minutes` 5–60, `password_reset_max_attempts` 1–10, `temporary_password_hours` 1–168, `payment_instructions` (objet FR/EN)
GET	`/api/v1/admin/reports/establishments`	Console	—	—	—	—	`billing`, `auditor`	Rapport de la plateforme : une ligne par établissement et par devise (JSON, CSV, PDF)
GET	`/api/v1/admin/reports/establishments/:id`	Console	—	—	—	—	`billing`, `auditor`	Rapport mensuel agrégé d'un établissement (JSON, CSV, PDF)
GET	`/api/v1/admin/tickets`	Console	—	—	—	—	`support`	Demandes d'assistance de tous les établissements (statut, catégorie, établissement, ouvertes)
GET	`/api/v1/admin/tickets/:id`	Console	—	—	—	—	`support`	Demande et messages, notes internes comprises
POST	`/api/v1/admin/tickets/:id/messages`	Console	—	—	—	—	`support`	Répondre, ou ajouter une note interne invisible pour l'établissement
PATCH	`/api/v1/admin/tickets/:id`	Console	—	—	—	—	`support`	Statut, gravité, personne assignée
GET	`/api/v1/admin/errors`	Console	—	—	—	—	`support`, `auditor`	Erreurs techniques regroupées
POST	`/api/v1/admin/errors/:id/resolve`	Console	—	—	—	—	`support`	Marquer une erreur comme résolue
GET	`/api/v1/admin/notifications`	Console	—	—	—	—	—	Notifications de la console
POST	`/api/v1/admin/notifications/read`	Console	—	—	—	—	—	Tout marquer comme lu
GET	`/api/v1/admin/overview`	Console	—	—	—	—	—	Indicateurs d'exploitation (abonnements, paiements, demandes, erreurs)

Récapitulatif

Section	Points d'accès
Mode installation (serveur sans base)	5
Service et référentiels	3
Inscription et rattachement	5
Authentification et compte	15
Établissement, équipe et droits	14
Abonnement et paiement	9
Assistance	6
Catalogue	12
Clients et fournisseurs	5
Documents de vente	11
Achats	6
Stock	6
Dépenses	6
Paiements, caisses et taux de change	6
Caisse (Nhill POS)	24
Rapports et journal d'activité	10
Console — accès des administrateurs	6
Console — établissements	12
Console — formules et droits	13
Console — facturation	12
Console — assistance et exploitation	17
Total	**203**